



**TRƯỜNG ĐẠI HỌC
BÁCH KHOA HÀ NỘI**
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

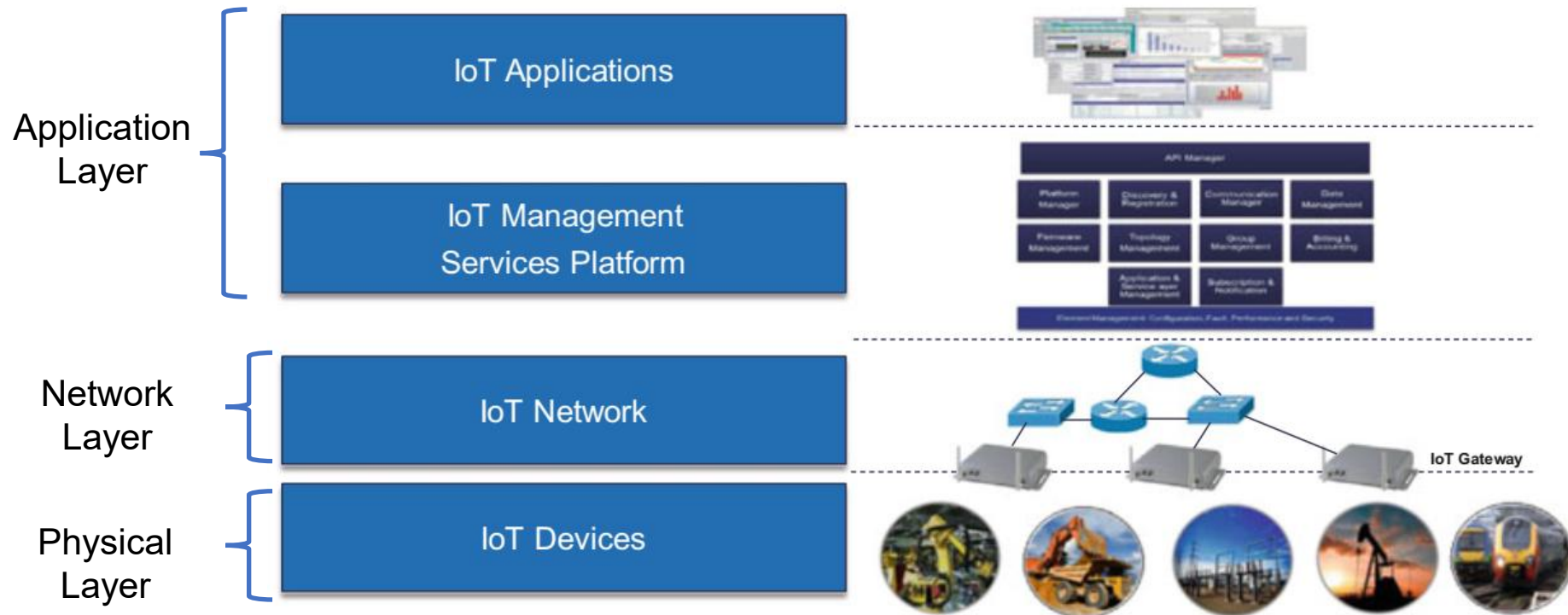
CHƯƠNG 7

BẢO MẬT TẦNG ỨNG DỤNG

ONE LOVE. ONE FUTURE.

- Quản lí truy cập
 - Quản lí truy cập với giao thức công bố/đăng kí (publish/subscribe)
 - Quản lí truy cập với giao thức truyền thông (communication)
- MQTT
- QUIC
- MQTT over QUIC

IoT Stack



Quản lí truy cập và định danh cho IoT?

- Phạm vi mở rộng:
 - Giải pháp truyền thống: Kết nối các thiết bị di động, máy tính với cơ chế mật khẩu mạnh cho việc quản lí truy cập hay các phần mềm quét mã độc và mã hóa ổ cứng để tránh mất mát thông tin.
 - IoT: Số lượng thiết bị lớn, đặc biệt tăng nhanh trong tương lai.
- Bảo mật trong triển khai
 - Thuê các giải pháp bảo mật cho IoT thay vì tự triển khai.
 - Cơ chế quản lí truy cập giữa nhà cung cấp giải pháp và các thiết bị với các ràng buộc nhất định.

Giới thiệu về quản lí định danh và truy cập

- Quản lí truy cập

- Các thiết bị (cảm biến, v.v) không chỉ gửi dữ liệu tới máy chủ trung tâm mà còn tương tác với các thiết bị khác để thực hiện nhiệm vụ nào đó.

→ **Cơ chế quản lí truy cập năng động** cho các thiết bị và thông tin ở **nhiều mức khác nhau**.

- Tấn công

- Tấn công phá hoại hệ thống IoT
- Quyền riêng tư của người dùng



**TRƯỜNG ĐẠI HỌC
BÁCH KHOA HÀ NỘI**
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

Quản lí truy cập

ONE LOVE. ONE FUTURE.

- Quản lí truy cập với giao thức công bố/đăng kí (publish/subscribe)
- Quản lí truy cập với giao thức truyền thông (communication)

Quản lý truy cập với giao thức công bố/đăng kí

- Giao thức MQTT

- Không phải tất cả client đều có quyền đăng kí và xuất bản tất cả các chủ đề (topic).

→ Cơ chế điều khiển truy cập

- Access control list

- Lưu trữ danh sách các nhà xuất bản và nhà công bố được ủy quyền

- Cơ chế điều khiển truy cập

- Ánh xạ giữa tên đăng nhập (trong MQTT connect) và các chủ đề.
- Ánh xạ giữa các chứng chỉ và các chủ đề.

Quản lý truy cập với giao thức truyền thông

- Có sự khác biệt so với giao thức công bố/đăng kí
- ZigBee
- **Access control list (ACL)**
 - **Kiểm tra nút mạng** bên cạnh có tin cậy hay không
 - Địa chỉ nút bên cạnh, chính sách bảo mật, khóa và vector khởi tạo
 - Sau khi nhận được thông tin từ nút bên cạnh, nút nhận được sẽ kiểm tra ACL để xác định xem kết nối đó có tin cậy hay không.

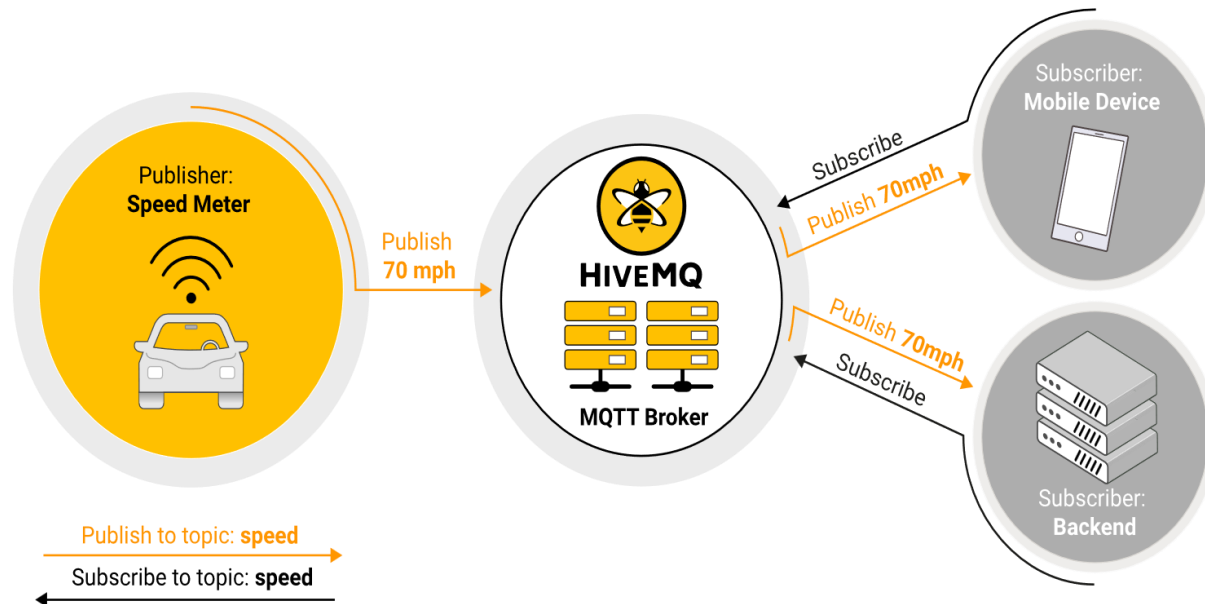


**TRƯỜNG ĐẠI HỌC
BÁCH KHOA HÀ NỘI**
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

MQTT

ONE LOVE. ONE FUTURE.

- MQTT (Message Queue Telemetry Transport)
 - Kiến trúc publish/subscribe dành cho các thiết bị IoT
 - Hoạt động theo cơ chế sự kiện để truyền thông điệp tới các client (subscriber).
 - Thành phần: MQTT client và MQTT broker



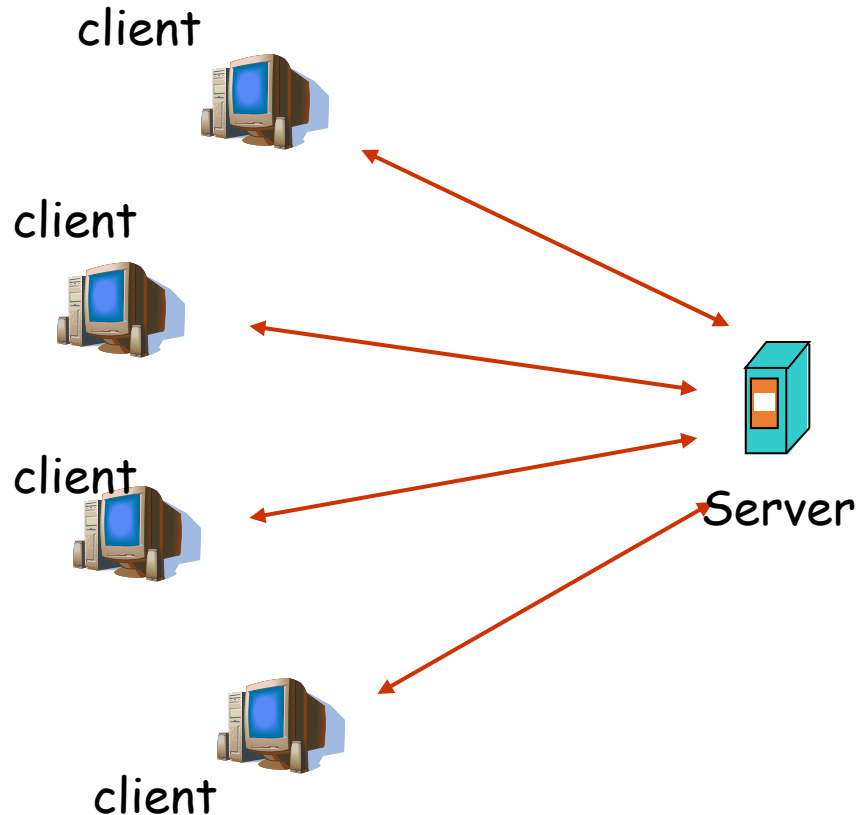
Kiến trúc client/server

clients:

- Trao đổi trực tiếp với server
- Có thể kết nối không liên tục
- Địa chỉ IP động
- Không trao đổi và giao tiếp với nhau

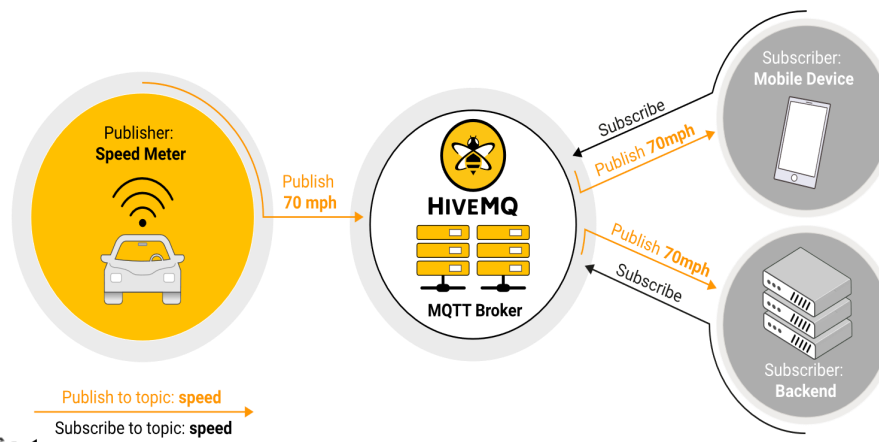
server:

- Luôn online
- Địa chỉ IP tĩnh
- Lập cụm server để hỗ trợ nhiều người dùng



Kiến trúc publish/subscribe

- Kiến trúc client/server
 - Client giao tiếp với server có thể dẫn đến nút thắt cổ chai phía server
- Kiến trúc publish/subscribe
 - Publisher: Thiết bị (cảm biến, v.v) gửi dữ liệu đến broker.
 - Subscriber: Thiết bị khác (điện thoại, máy tính, v.v) nhận được dữ liệu từ broker.
 - Tách biệt giữa publisher và subscriber.
 - Broker sẽ xử lý giao tiếp giữa 2 thành phần này, như vậy sẽ nhanh và hiệu quả hơn kiến trúc client/server



- Đặc điểm

- Tách biệt về không gian: publisher và subscriber không cần phải biết nhau (không trao đổi địa chỉ IP và port)
- Tách biệt về thời gian: publisher và subscriber không cần phải chạy cùng lúc.
- Tách biệt về đồng bộ hóa: Các hoạt động trên cả hai thành phần không bị gián đoạn trong quá trình publish hoặc subscribe.

- Ưu điểm

- Nhẹ và hiệu quả: MQTT giảm thiểu tài nguyên cần thiết cho máy khách và băng thông mạng.
- Giao tiếp hai chiều: MQTT tạo điều kiện thuận lợi cho giao tiếp giữa các thiết bị và máy chủ, hỗ trợ xuất bản và đăng ký. MQTT cũng cho phép truyền phát tin nhắn đến các nhóm thiết bị.
- Khả năng mở rộng: MQTT có thể mở rộng để hỗ trợ hàng triệu thiết bị trong hệ sinh thái IoT.
- Mức Chất lượng dịch vụ (QoS): MQTT chỉ định các mức QoS khác nhau để đảm bảo phân phối tin nhắn đáng tin cậy.
- Tính năng bảo mật: MQTT hỗ trợ mã hóa TLS để bảo mật tin nhắn và các giao thức xác thực để xác minh máy khách.



**TRƯỜNG ĐẠI HỌC
BÁCH KHOA HÀ NỘI**
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

QUIC

ONE LOVE. ONE FUTURE.

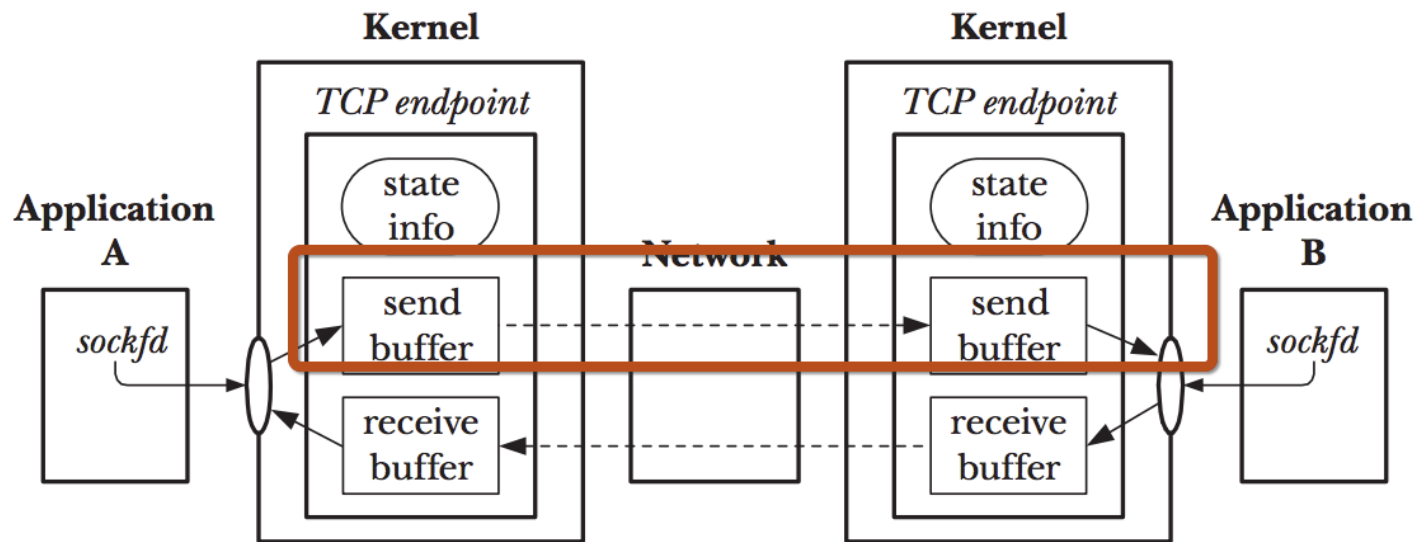
Nhắc lại về TCP

- Giao thức hướng liên kết
 - Bắt tay ba bước
- Giao thức truyền dữ liệu theo dòng byte, tin cậy
 - Sử dụng vùng đệm
- Truyền theo kiểu pipeline, sử dụng sliding windows.
 - Tăng hiệu quả
- Kiểm soát luồng
 - Bên gửi không làm quá tải bên nhận (thực tế: quá tải)
- Kiểm soát tắc nghẽn
 - Việc truyền dữ liệu không nên làm tắc nghẽn mạng (thực tế: luôn có tắc nghẽn)

Vấn đề của TCP [1]

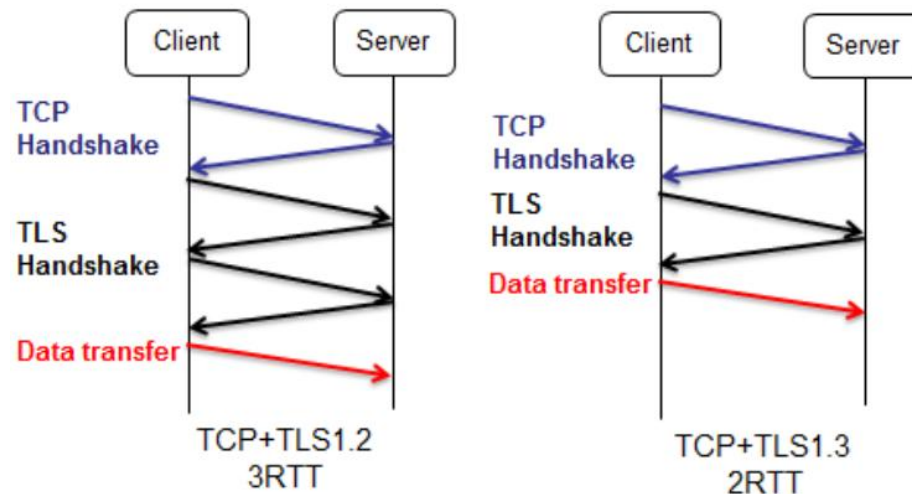
- Triển khai

- TCP được triển khai trên nhân của hệ điều hành (OS kernel)
- Muốn thay đổi TCP thì cần cập nhật hệ điều hành
- Việc cập nhật hệ điều hành có thể mất tới vài tháng do kiểm tra tính ổn định, hiệu năng, v.v.



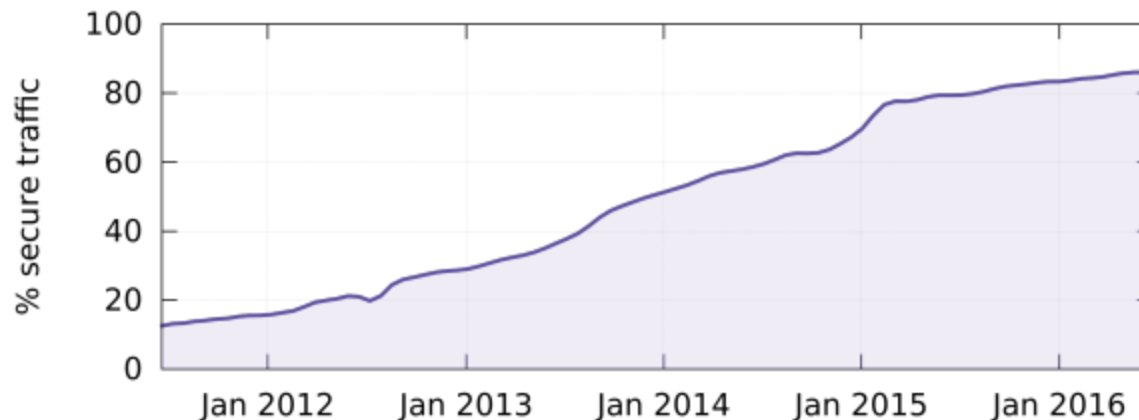
Vấn đề của TCP [1]

- Độ trễ trong quá trình bắt tay (handshake)
 - HTTP: HyperText Transfer Protocol
 - Mô hình Client/Server
 - Client: yêu cầu truy nhập tới các trang web (và hiển thị chúng trên trình duyệt)
 - Server: Nhận yêu cầu và trả lời cho client
 - HTTPS: sử dụng liên kết SSL/TLS kết hợp với TCP để truyền các thông điệp HTTP



Vấn đề của TCP [1]

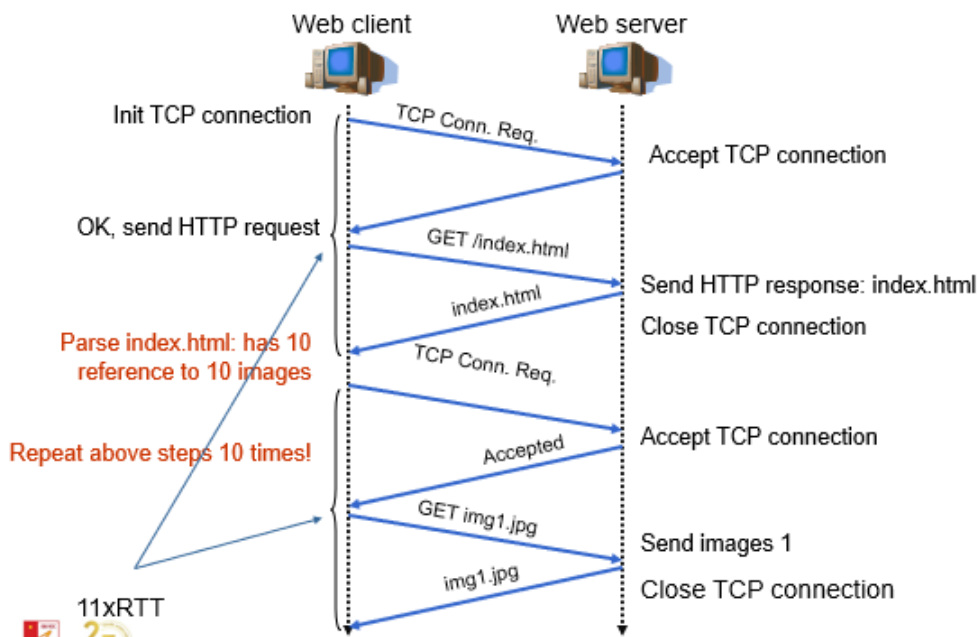
- Độ trễ trong quá trình bắt tay (handshake)
 - Internet đang chuyển từ lưu lượng không an toàn sang an toàn, nhưng lại tăng thêm độ trễ
 - Các nghiên cứu đang tập trung vào việc giảm độ trễ trong giao thức tầng giao vận.



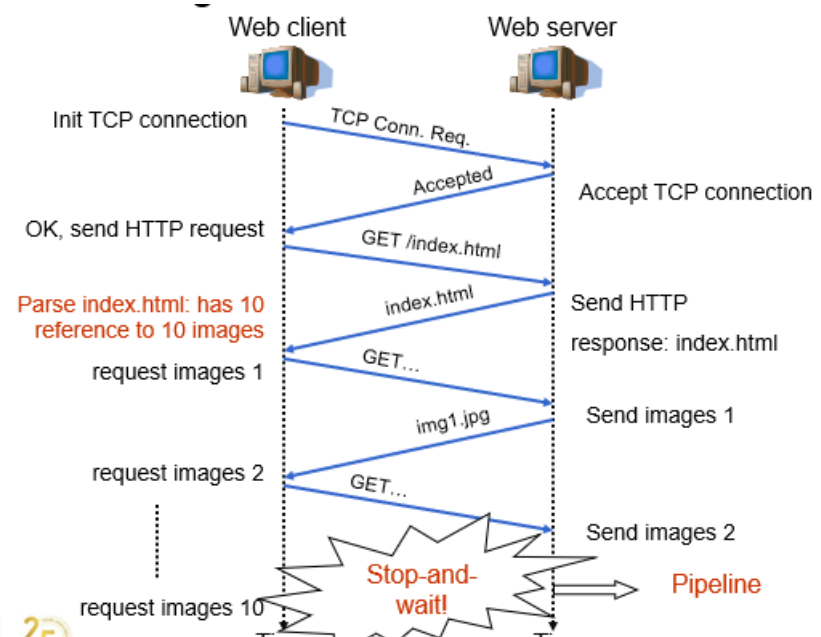
Xu thế tăng dần lưu lượng web mã hóa tới các máy chủ Google.

Vấn đề của TCP [1]

- Head-of-line Blocking Delay
 - HTTP/1.0. HTTP/1.1 và HTTP/2.0



HTTP/1.0

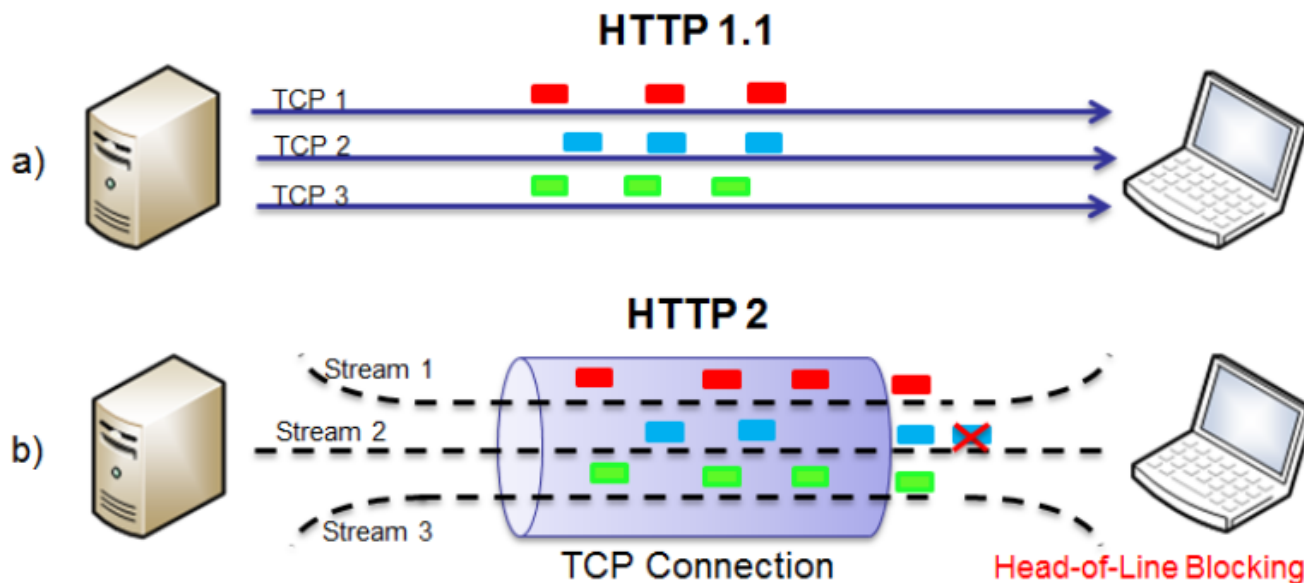


HTTP/1.1

Vấn đề của TCP [1]

• Head-of-line Blocking Delay

- Gói tin bị mất ở đầu hàng đợi ngăn chặn tất cả các gói tin tiếp theo được truyền đi.
- Các gói tin tiếp theo được truyền khi gói tin bị mất được truyền lại thành công.

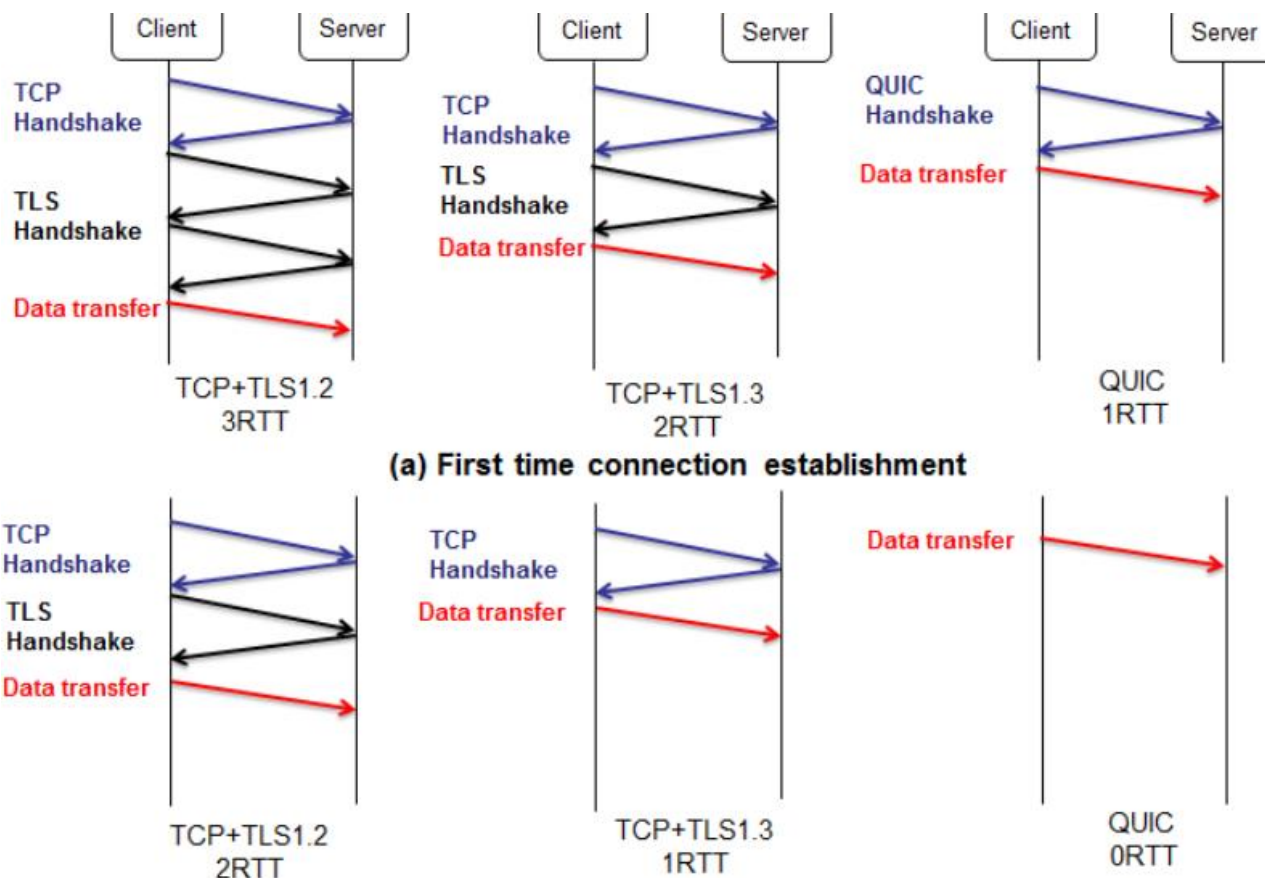


Quick UDP Internet Connection (QUIC)

- QUIC là gì giao thức tầng giao vận, được phát triển bởi Google từ 2012.
 - Dựa trên UDP thay vì TCP.
 - QUIC được triển khai như một ứng dụng thay vì trên OS như TCP.
 - Giải quyết một số hạn chế của TCP+TLS về triển khai, độ trễ và HoL blocking.
 - Google đã tích hợp QUIC vào Chrome năm 2013 và tất cả các dịch vụ của Google năm 2017.
 - HTTP/3 dựa trên QUIC được đánh giá sẽ là sự thay thế cho các phiên bản HTTP hiện nay.
 - Năm 2023, IETF chuẩn hóa QUIC thành 1 giao thức chung cho toàn thế giới.

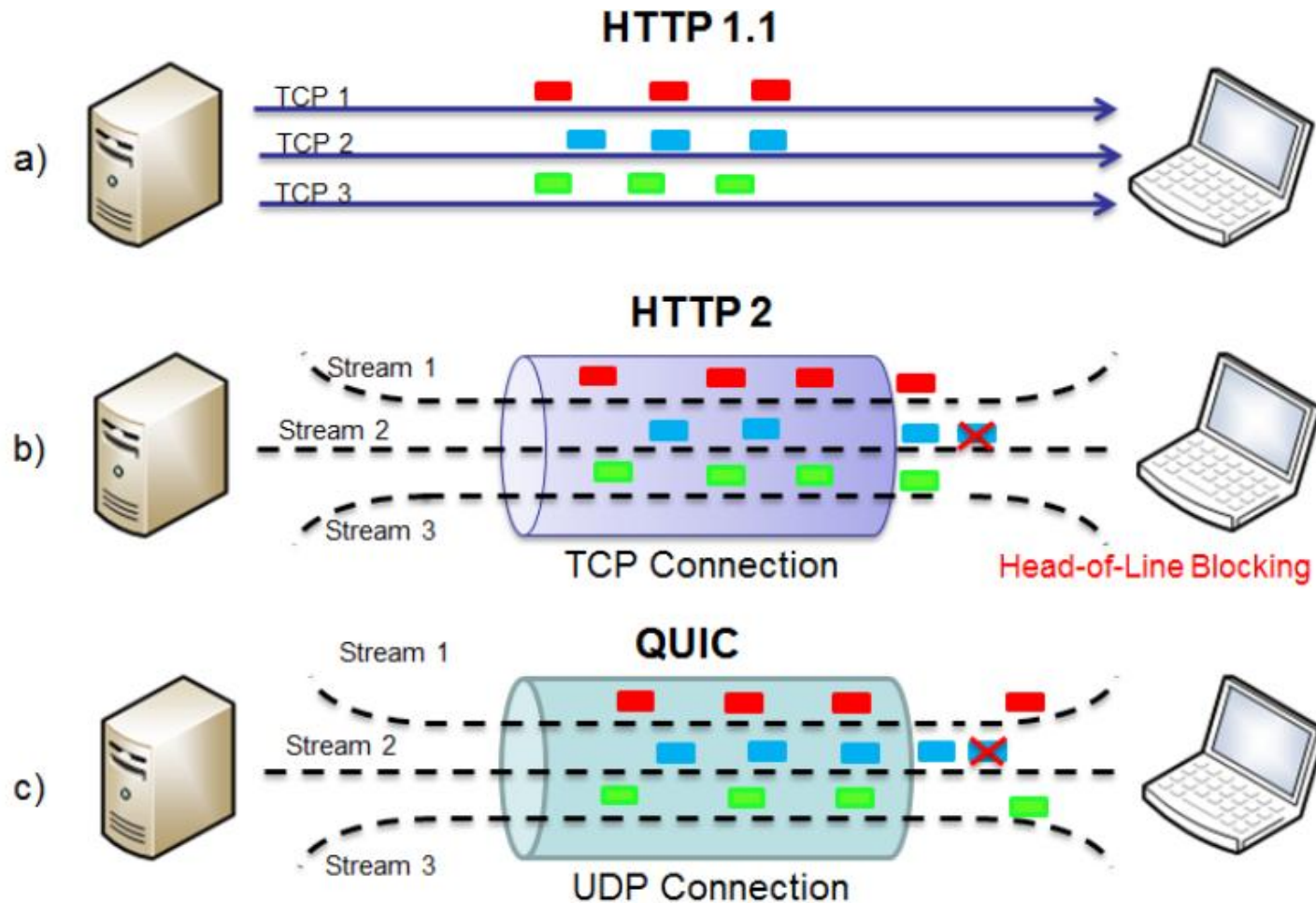
Đặc điểm của QUIC

- Quá trình thiết lập kết nối
 - Kết hợp transport and crypto handshake để giảm thiểu độ trễ kết nối.



Đặc điểm của QUIC

- Stream multiplexing



Đặc điểm của QUIC

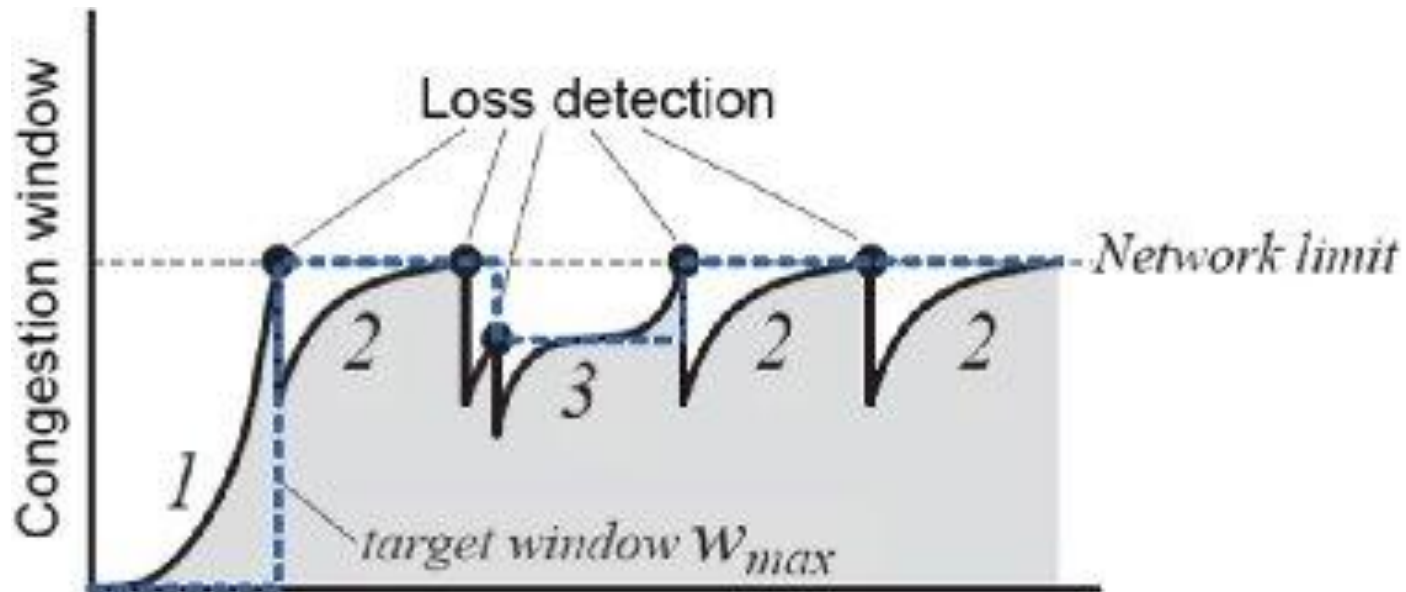
- Xác thực và mã hóa
 - Các gói QUIC được xác thực đầy đủ và hầu hết được mã hóa.



Figure 5: Structure of a QUIC packet, as of version 35 of Google's QUIC implementation. Red is the authenticated but unencrypted public header, green indicates the encrypted body. This packet structure is evolving as QUIC gets standardized at the IETF [2].

Đặc điểm của QUIC

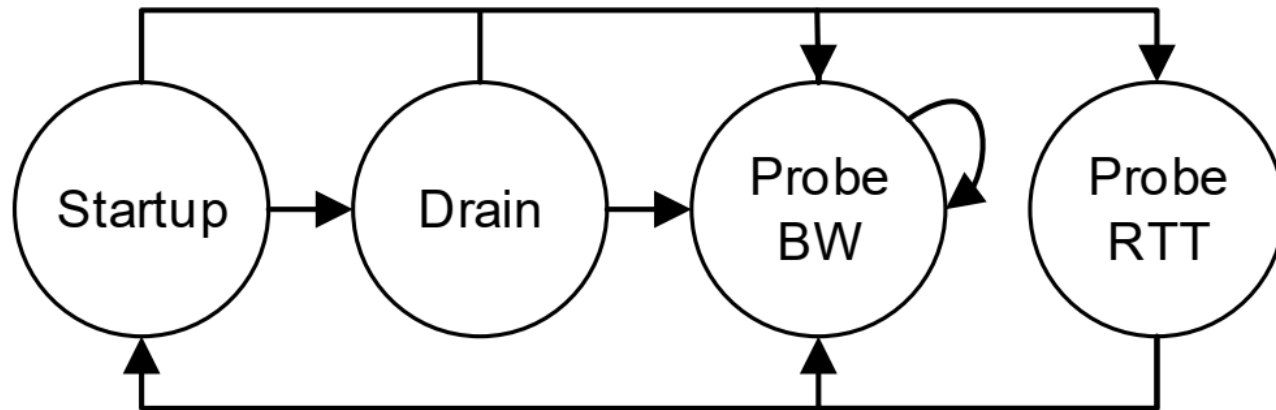
- Quản lý tắc nghẽn
 - Thuật toán quản lý tắc nghẽn AIMD:
 - Khởi động chậm
 - Tránh tắc nghẽn
 - Khôi phục nhanh
- TCP và QUIC đều có thể sử dụng Cubic



Đặc điểm của QUIC

- Quản lí tắc nghẽn

- QUIC có thể sử dụng một số thuật toán quản lí tắc nghẽn khác ngoài Cubic như BBR (Bottleneck Bandwidth and Round-Trip Time)
- BBR [2] là thuật toán điều khiển tắc nghẽn dựa vào rate, điều chỉnh tốc độ gửi dữ liệu theo pacing gain và delivery rate.
- Được phát triển bởi Google, hiện tại đã công bố phiên bản 3.



Đặc điểm của QUIC

- BBR gồm 4 pha:
 - Startup: tăng tốc độ gửi theo pacing_gain của $2/\ln(2)$. Trong 3 round liên tiếp mà tăng tốc độ gửi chỉ dẫn đến tăng 1 lượng nhỏ delivery rate ($<25\%$) thì chuyển qua pha Drain.
 - Drain: Giảm tốc độ gửi dữ liệu theo pacing_gain của $2/\ln(2)$ cho tới khi dữ liệu trên đường truyền đạt mức $bdp = b_r \cdot RTT_{min}$ với b_r là delivery rate.
 - ProbeBW: Thăm dò băng thông qua pacing gain của $[1.25, 0.75, 1, 1, 1, 1, 1, 1]$. Mỗi giá trị sẽ được thực hiện trong 1 RTT.
 - ProbeRTT: Cập nhật RTT_{min} sau mỗi 10s.

- Thay đổi kết nối
 - TCP sử dụng 4-tuple (IP nguồn, IP đích, port nguồn và port đích) để làm ID cho mỗi kết nối.
 - Khi thay đổi mạng, IP thay đổi và khi đó kết nối sẽ bị mất.
 - QUIC sử dụng 64-bit Connection ID để làm định danh, nên khi thay đổi mạng sẽ không ảnh hưởng đến kết nối.
 - Ví dụ: chuyển từ wifi sang 5G, mạng dây, v.v.

Multipath QUIC

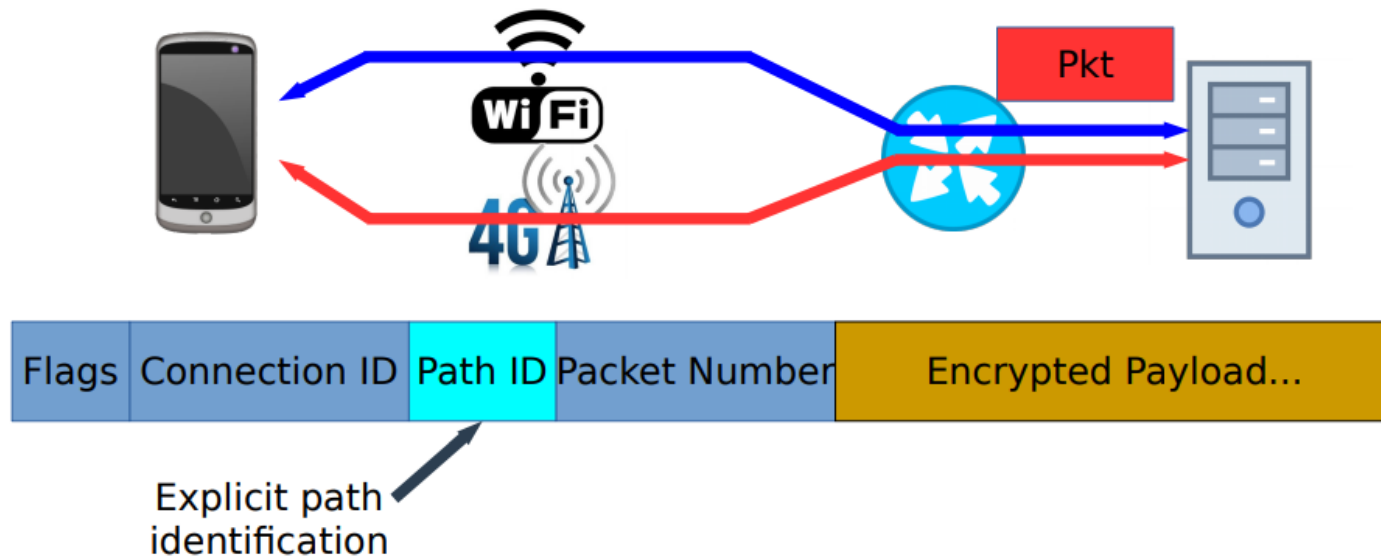
- QUIC sử dụng single-path flow



Multipath QUIC

- Multipath QUIC [3-4]

- Kết hợp băng thông của nhiều đường để tối ưu quá trình truyền.
- Thay đổi mạng mà không gián đoạn (seamless network handover).
 - Có thể kết nối tới mạng Wifi mới trong khi vẫn sử dụng LTE.





**TRƯỜNG ĐẠI HỌC
BÁCH KHOA HÀ NỘI**
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

MQTT over QUIC

ONE LOVE. ONE FUTURE.

- Hạn chế của MQTT

- Kết nối thường xuyên bị gián đoạn do chuyển đổi mạng
- Khó thiết lập lại kết nối sau khi ngắt kết nối: hệ điều hành chậm giải phóng tài nguyên sau khi ngắt kết nối và lớp ứng dụng không thể cảm nhận trạng thái ngắt kết nối kịp thời.
- Trong môi trường mạng yếu, không đồng đều, việc truyền dữ liệu bị chặn do tắc nghẽn, mất gói tin và truyền lại.
- Ví dụ, người dùng xe có kết nối Internet thường gặp phải các vấn đề: xe có thể chạy ở vùng núi, mỏ, đường hầm, v.v., điều này có thể gây gián đoạn kết nối khi vào vùng mất tín hiệu hoặc chuyển đổi thụ động các trạm gốc (base station). Việc gián đoạn kết nối thường xuyên và thiết lập kết nối chậm có thể dẫn đến trải nghiệm người dùng kém.

MQTT over QUIC

- Ưu điểm

- Low connection overhead and multi-path
- 1-RTT trong kết nối đầu tiên và 0-RTT trong các kết nối tiếp theo.
- Hỗ trợ di trú kết nối (connection migration)
- Nhiều ưu điểm khác của QUIC

